

AI Weaponisation of Zero-Days — Research Scratchpad

Investigation Start: 6 June 2026
Core Question: Is AI genuinely accelerating the weaponisation of vulnerabilities, or is the narrative ahead of the evidence?

THESIS UNDER TEST

AI is compressing the time between vulnerability discovery and weaponisation, shifting the advantage to attackers and rendering current patch cycles structurally inadequate.

DECISION TREE

Is AI accelerating vulnerability weaponisation?

— ROUND 1: What does the research and media say? COMPLETE

— Finding: Strong narrative from GTIG, Mandiant, Fang et al., Palo Alto, CSIS. First confirmed AI zero-day (GTIG, May 2026). Directionally alarming but mostly N=1 cases.

— ROUND 2: Do disclosure-to-exploit timelines support it? COMPLETE

— Finding: TTE collapsed from 63 days (2018) to -7 days (2025). 28.3% of CVEs exploited within 24hrs. 42% exploited pre-disclosure. Seven CVE case studies mapped. Pattern is real regardless of cause.

— ROUND 3: Does AI availability timeline correlate? COMPLETE

— Finding: Exploitation acceleration tracks AI model availability. No capable open-weight model before Jan 2025 (DeepSeek R1). Verizon DBIR vuln exploitation: 5% → 14% → 20% → 31% maps to pre-AI → GPT-4 → open models → full ecosystem. Correlation strong, causation unproven at scale.

— ROUND 4: Do mandatory breach disclosures confirm it? COMPLETE

— Finding: Breaches up 79% over 5 years (ITRC). But growth is steady slope not hockey stick. 70% of notices omit attack vector. Ground truth is deliberately obscured. Cannot prove or disprove from disclosure data alone.

— ROUND 5: CVE volume & severity vs AI framework launches? COMPLETE

— Finding: Total MS CVEs roughly flat (-6% in 2025), BUT critical CVEs surged 16%. May 2026 = 31 critical in single month (4x avg). MDASH found 16/137 CVEs. Defensive AI directly inflating severity. Q2 2026 critical % jumped from 5.3% to 15.0% – coincides with

Glasswing + MDASH going live.

— ROUND 6: Bug bounty submission volume & severity PENDING

- Hypothesis: If AI is helping find bugs, HackerOne/Bugcrowd submission volumes should spike, severity should shift upward, and time-to-find should compress.
- Data needed:
 - HackerOne annual report submission volumes 2023–2025
 - Severity distribution shift (critical/high vs medium/low)
 - XBOW impact on platform dynamics (already in project knowledge)
 - Bugcrowd state of bug bounty data
- What would PROVE thesis:
Submission volume spike post-mid-2025. Critical severity share increasing. Automated/AI-flagged submissions appearing.
- What would CHALLENGE thesis:
Flat or declining submissions. Severity distribution unchanged. Human researchers still dominating.

— ROUND 7: CISA KEV catalog velocity COMPLETE

- Hypothesis: If exploitation is accelerating, the rate of KEV additions (confirmed in-the-wild exploitation) should increase.
- Finding: KEV additions grew 20% in 2025 (245 vs 185 in 2024). BUT total CVEs published also grew 20.6% (48,185 vs 40,009). KEV-to-CVE ratio barely moved: 0.46% → 0.51%. The proportion of CVEs being exploited is FLAT. KEV growth is explained by CVE volume growth, not AI acceleration.
- CWE distribution IS interesting:
Logic flaws: 75% of top KEV CWEs (cmd injection, deser, path trav)
Memory corruption: 25% (UAF, OOB write)
3:1 ratio matches AI capability profile (logic > memory)
- Old vulns re-weaponised: +45% increase in older CVE additions (94 from 2024-and-earlier, vs avg 65 in 2023-2024)
- Verdict: MIXED – does NOT support breadth acceleration. CWE class mix and old-vuln rediscovery are AI-consistent. KEV measures binary exploited/not, doesn't measure SPEED.
- KEY INSIGHT: KEV data challenges the thesis on volume but doesn't address the speed question (Mandiant TTE does that). The two datasets measure different things.

— ROUND 8: EPSS calibration drift PENDING

- Hypothesis: If AI is changing who can exploit what, EPSS predictions should be losing accuracy – CVEs scored low are getting exploited, CVEs scored high aren't.
- Data needed:
 - EPSS accuracy/calibration reports 2024 vs 2025 vs 2026
 - False negative rate (low EPSS score, actually exploited)
 - FIRST.org EPSS performance data
 - Comparison with MS Exploitability Index accuracy

- What would PROVE thesis:
 - Increasing false negatives. EPSS underestimating exploitation probability for vulnerability classes AI handles well (logic flaws).
 - Model trained on pre-AI attacker baseline losing predictive power.
- What would CHALLENGE thesis:
 - EPSS accuracy stable or improving. Predictions holding.
 - Pre-AI attacker capability assumptions still valid.
- ROUND 9: Vendor self-discovery vs external discovery ratios PENDING
 - Hypothesis: If defensive AI is genuinely finding bugs vendors missed, the ratio of internally-discovered vs externally-reported CVEs should shift toward internal. This proves defensive AI works but also proves the bugs were always there.
 - Data needed:
 - Microsoft CVE credit data (who reported each CVE)
 - Apple Product Security credit data
 - Google Chrome/Android credit data
 - Palo Alto self-scan results (post-Glasswing)
 - Historical comparison: internal vs external 2023 → 2024 → 2025 → 2026
 - What would PROVE thesis (defensive side):
 - Sharp increase in vendor self-discovery post-AI tooling.
 - MDASH's 16/137 in May 2026 is the first data point.
 - What would CHALLENGE thesis:
 - Ratios unchanged. Vendors were already finding most bugs internally.
 - AI hasn't shifted the discovery source.

- ROUND 10: Vulnerability class distribution shift COMPLETE
 - Hypothesis: AI is better at finding logic flaws than memory corruption. If AI is changing what gets found, the MIX of vulnerability classes in patch data should shift toward logic/auth/authz flaws and away from buffer overflows.
 - Finding: CLASS SHIFT IS REAL.
 - CWE-862 (Missing Authorization): +62% YoY in 2025 NVD data
Now 4th most common weakness at 5.2% of all CVEs
 - Azure/Entra ID: 22% of all MS critical CVEs (doubled from 2023)
 - Traditional EoP: dropped from 34% avg (2020-24) to 28% (2025)
 - Memory corruption (CWE-119): dropped from top NVD positions
 - NVD Top 10 2025: 7 of 8 top positions are logic-class flaws
 - KEV 2025 CWE split: 75% logic vs 25% memory (3:1 ratio)
 - Three competing explanations:
 - A) AI helping defenders/researchers FIND logic flaws faster
 - B) Cloud migration naturally produces more logic/auth code
 - C) AI-generated code CREATING auth gaps (Zafran hypothesis)
 Cannot isolate single cause from class data alone.
 - ACCESS LADDER CAUSALITY (key finding):
 - The discoverers map to the access timeline:
 - Tier 0 – Vendor proprietary AI (Google Big Sleep 2024, MS MDASH 2025)
 - Found: SQLite zero-day, 16 May 2026 Patch Tuesday CVEs

→ Effect: Immediate (scanning own code with privileged access)

Tier 1 – Glasswing/Mythos (Apr 7 2026, 12 partners + ~40 orgs)

- Found: 10,000+ high/critical vulns in first 2 months
- Partners: AWS, Apple, Broadcom, Cisco, CrowdStrike, Google, JPMorganChase, Linux Foundation, Microsoft, NVIDIA, Palo Alto
- Expanded Jun 2 2026: +150 orgs in 15 countries
- OpenAI Daybreak (May 2026): same partners running both stacks
- Mythos NOT planned for public release

Tier 2 – Elite researchers + commercial AI (mid-2023 onward)

- Had: GPT-4, Claude 3.5 Sonnet, GPT-4o
- Found: CVE-2025-55241 (Entra ID CVSS 10.0, Jul 2025)
Discovered by Dirk-jan Mollema (DEF CON/Black Hat speaker)
- Effect: CWE-862 surge visible ~12 months after access
- This tier aligns with the 2025 authorization flaw spike

Tier 3 – Open-weight capable (Jan 2025, DeepSeek R1)

- Available to: nation-states, sophisticated criminals
- Effect: Not yet distinguishable in aggregate data

Tier 4 – General commercial (Q1 2026, Opus 4.6)

- Available to: general security professionals, the user
- Effect: Not yet observable. ~18 months behind Tier 2.

Tier 5 – Everyone else (free/cheap models)

- Available to: SMBs, commodity attackers
- Effect: Not applicable to vulnerability discovery

PATTERN: Effects appear in order of access.

Elite researchers first (2024-25), vendor teams second (Q2 2026), general population not yet. The people finding the bugs are the people who had the tools first. Circumstantially strong for causality but not proof (would need discoverer confirmation of AI tool usage).

Verdict: SUPPORTS thesis with nuance.

Class shift is real and AI-consistent. Access ladder timing adds circumstantial causality. But cloud migration and AI-generated code are confounding variables.

ROUND 11: Exploit maturity speed – CVE to public PoC PENDING

Hypothesis: If AI helps write exploit code faster, the time from CVE publication to public PoC on GitHub/ExploitDB should be compressing.

Data needed:

- ExploitDB/GitHub PoC publication dates vs CVE disclosure dates
- Median and distribution of CVE-to-PoC time 2023 → 2024 → 2025 → 2026
- Comparison by vulnerability class (logic vs memory corruption)
- VulnCheck or similar aggregator data on exploit code availability

What would PROVE thesis:

Median PoC development time compressing. Logic flaw PoCs appearing faster than memory corruption PoCs (matching AI capability profile).

What would CHALLENGE thesis:

PoC timing unchanged. No class-level difference.

PoC availability driven by researcher interest not tooling.

— ROUND 12: Zero-day broker market disruption PENDING

— Hypothesis: If AI commoditises exploit discovery, the exclusive zero-day broker model breaks. Zerodium shutting down (Jan 2025) may be the first signal.

— Data needed:

- Zerodium shutdown timeline and industry commentary
- Crowdfense pricing changes 2024–2026
- Trend Micro ZDI acquisition volumes
- Market commentary on zero-day pricing trends

— What would PROVE thesis:

Broker shutdowns/consolidation. Prices falling (oversupply).
Or prices spiking (more actors competing for remaining inventory as AI enables more buyers).

— What would CHALLENGE thesis:

Market stable. Zerodium shutdown unrelated to AI.
Prices steady, supply/demand unchanged.

— ROUND 13: Patch bypass / variant discovery rate PENDING

— Hypothesis: AI can take a patched CVE and quickly find variants in the same component. If this is happening, we should see more CVE clusters (multiple related CVEs in same component, same release window).

— Data needed:

- MS Patch Tuesday CVE clustering analysis (related CVEs per component)
- Frequency of "variant" CVEs appearing in subsequent months
- May 2026 Word cluster (4 RCEs, identical CVSS) as case study
- Historical comparison: cluster frequency 2023 → 2024 → 2025 → 2026

— What would PROVE thesis:

Increasing CVE clustering. More variants found per component.
Faster re-discovery after patches (AI scanning patched code for related flaws).

— What would CHALLENGE thesis:

Clustering unchanged. Variants found at historical rate.
No acceleration in related-CVE discovery.

— ROUND 14: East vs West AI model capability – benchmarked PENDING

— PURPOSE: Pure capability comparison. Not a threat assessment. Not about who is using what offensively. Simply: how do Eastern AI models (DeepSeek, Qwen, GLM, Yi, Baichuan) compare to Western models (GPT-5, Claude Opus, Gemini) on benchmarks most relevant to vulnerability identification capability?

China using Claude is a DISTRACTION – it doesn't prove they needed it. It proves nothing about relative AI capability.

— Data needed:

- Side-by-side benchmark scores: Eastern vs Western models on coding (SWE-bench, HumanEval, LiveCodeBench) reasoning (GPQA, ARC-AGI, MATH, GSM8K) agent tasks (SWE-bench Verified, tool use benchmarks)

- Timeline of when each model family crossed key score thresholds
- Any security-specific benchmarks (CyberSecEval, CTFBench, CyberGym) with Eastern model results
- DeepSeek V3/R1, Qwen 3, GLM-5, Kimi K2 benchmark positions vs GPT-5, Claude Opus 4.7, Gemini 2.5 Pro

— What would PROVE thesis:
 Eastern models at or near parity on relevant benchmarks.
 The capability for vuln ID is democratised globally,
 not concentrated in Western labs.

— What would CHALLENGE thesis:
 Significant gap on reasoning/coding benchmarks.
 Eastern models behind by 12+ months on relevant capability.
 Vuln ID capability remains concentrated in Western frontier.

— ROUND 15: Benchmark threshold for vulnerability identification COMPLETE

— Finding: THE THRESHOLD IS A COMBINATION, NOT A SINGLE SCORE.

The Fang et al. cliff (GPT-4 87% vs everything else 0%) maps to:
 HumanEval >60% AND MATH >45% AND multi-step reasoning capability.
 Below this combination: 0%. Above it: viable. Step function, not gradient.

Three tiers of vulnerability capability:

TIER A – Basic vuln identification (is this vulnerable?)
 Threshold: HumanEval >65%, SWE-bench >25%, GPQA >35%
 Crossed: GPT-4 (Mar 2023), Claude 3 (Mar 2024)
 VulDetectBench: models achieve 80%+ on binary identification

TIER B – Exploit development (write working PoC)
 Threshold: SWE-bench >45%, GPQA >55%, reasoning chains
 Crossed: GPT-4+o1 (Sep 2024), DeepSeek R1 (Jan 2025)
 Fang et al. 87% success at this tier with GPT-4

TIER C – Zero-day discovery (find unknown vulns in codebases)
 Threshold: SWE-bench >70%, agent benchmarks >40%
 Crossed: Claude Opus 4+ (2025), GPT-5 (Aug 2025), Mythos (Apr 2026)
 CyberGym: 30% single-trial, 35 zero-days found autonomously
 SecVulEval: best model only 23.83% F1 – still unreliable

UK AISI KEY FINDING:
 Open-to-closed source gap has narrowed to 4-8 months.
 Cyber task time horizon doubling every 8 months.
 Apprentice-level: <9% (2023) → 50% (2025)
 Expert-level (10+ year tasks): first completed 2025.

IMPLICATION FOR R14:
 The 4-8 month lag means ANY model family that crosses the
 threshold will be followed by open-weight equivalents within
 two quarters. The measuring stick is now defined – apply it
 to Eastern models in R14.

— Verdict: STRONG FINDING. Threshold defined, three tiers mapped,
 can now test any model family against it.

SCORING TREE 1 – Model Capability Comparison (Multi-Benchmark)

Purpose

Compare model-to-model capability across ALL available benchmarks.
Shows Western vs Eastern frontier models. Extrapolates Mythos position.
Answers: "How capable are the models at vulnerability work?"

Five Benchmarks for Triangulation

Benchmark	What It Measures	Tier Proxy	Best Western	Best Eastern	Gap
CSEBenchmark	Security knowledge/expertise	Tier A	GPT-4o: 85.4%	DeepSeek-V3: 84.9%	**0.5 pts – parity**
HardSecBench Sec@1	Security-aware code gen	Tier A–B	Opus 4.5: 42.9%	GLM-4.6: 42.9%	**0.0 pts – parity**
PACEBench	Autonomous attack execution	Tier B–C	Claude 3.7: 0.417	DeepSeek-R1: 0.133	**3.1x ratio**
CyberGym (single model)	Real vuln reproduction	Tier C	Sonnet 4: 17.9%	DS-V3/Qwen3 (lower)	**Significant**
GPQA Diamond	Deep reasoning (0-day proxy)	Reasoning	Mythos: 94.6%	DS V3.2: ~85%	**~10 pts**

The Pattern: Gap Expands with Task Complexity

Task Type	Gap	Interpretation
Security knowledge (can you answer?)	Near zero	Eastern knows as much
Security coding (can you write?)	Near zero	Equivalent code quality
Autonomous exploitation (can you chain?)	**3–5x behind**	Agentic gap – reasoning chains, tool use
Real vuln reproduction (can you do it?)	**Significant**	SWE-bench does NOT predict CyberGym
Deep reasoning (GPQA)	**~10 pts**	Reasoning depth gap

Extrapolated Model Positions (CyberGym axis)

Model	Origin	SWE-bench	GPQA Diamond	CyberGym (est.)
Qwen3 235B	Eastern	~65%	65.8%	~8%
DeepSeek R1	Eastern	49.2%	71.5%	~10%
DeepSeek V3.2	Eastern	~85%	~85%	~12%
GLM-5	Eastern	77.8%	~70%	~11%
MiniMax M2.5	Eastern	80.2%	–	~13%
Sonnet 4	**Western**	~65%	~82%	**17.9% (measured)**
Opus 4.5	Western	74.4%	~86%	~24%
Opus 4.6	Western	80.8%	~88%	~26%
Opus 4.7	**Western**	**87.6%**	**~90%**	**~28%**
Mythos	**Western (restricted)**	**~93% (est.)**	**94.6% (confirmed)**	**~34% (est.)**

Mythos Extrapolation Method

Mythos isn't benchmarked on SWE-bench or CyberGym. Estimated from:

- Expert-level cyber tasks: 73% (confirmed) vs Opus 4-class ~60% = 1.22x ratio
- GPQA Diamond: 94.6% (confirmed) – highest published score
- SWE-bench estimated ~93% by applying the 1.22x expert ratio
- CyberGym estimated ~34% by applying 1.22x to Opus 4.7's ~28%

Gap Summary from Tree 1

Level	GPQA Gap (Eastern best to target)	CyberGym Gap	Time Estimate
-------	-----------------------------------	--------------	---------------

Eastern → Opus 4.7	85% → 90% = **5 pts**	~12% → ~28% = **2.3x**	~4–6 months
Eastern → Mythos	85% → 94.6% = **9.6 pts**	~12% → ~34% = **2.8x**	~8–12 months
Eastern → MDASH	N/A	~12% → 96.55% = **8.0x**	Architectural gap

SCORING TREE 2 – MDASH-Anchored (Vendor-Privileged Ceiling)

Purpose

Anchor at MDASH's 96.55% CyberGym as the ceiling. MDASH finds bugs and builds patches – equivalent to zero-day discovery but defensive. MDASH has specialised Microsoft domain knowledge. Shows the gap between what's commercially available (Opus) and what's vendor-privileged (MDASH). Answers: "What's the gap between vendor AI and what anyone else can access?"

MDASH's 96.55% CyberGym score is the CEILING, not a general benchmark. It includes three stacked advantages no external model has:

1. **Source code access** – MDASH scans Microsoft's own code, not binaries
2. **MSRC historical knowledge** – trained on zero-day patterns, prior patch data, CVE history. Knows WHERE bugs have appeared before in the same components (96% retrospective recall on clfs.sys, 100% on tcpip.sys)
3. **100+ agent architecture** – debate, validate, deduplicate, prove stages. Found CVE-2026-33824 spanning 6 source files – invisible to any single model reviewing one function at a time

Any third-party model (Eastern OR Western) working without these advantages would score lower. The tree scales DOWN from MDASH using measured ratios.

The Validated Ratio Chain (MDASH → Sonnet 4)

Working downward from MDASH using ratios derived from cross-benchmark data:

Level	CyberGym Score	÷ Ratio	Ratio Source	Validates?
MDASH (system)	96.55%	–	CyberGym measured	✓ Measured
Mythos (single model)	~34.2%	÷2.82	System+knowledge multiplier	Estimated
Opus 4.7	~28.0%	÷1.22	Expert cyber ratio (73%/60%)	Estimated
Opus 4.6	~25.9%	÷1.08	SWE-bench scaling (87.6/80.8)	Estimated
Opus 4.5	~23.8%	÷1.09	SWE-bench scaling (80.8/74.4)	Estimated
Sonnet 4	~17.9%	÷1.33	HardSecBench ratio (42.9/32.3)	✓ Measured

Chain validation: $96.55 \div 2.82 \div 1.22 \div 1.08 \div 1.09 \div 1.33 = 17.8\% \approx 17.9\%$ ✓

The chain closes to within 0.1% of the measured CyberGym anchor.

Decomposing the MDASH 2.82x Multiplier

The 2.82x multiplier from Mythos to MDASH decomposes into:

Component	Multiplier	What It Represents	Reproducible?
Architecture	~2.0x	Multi-agent debate, prove stage, dedup	Yes – with engineering investment
Knowledge	~1.4x	MSRC zero-day/patch history, source access	No –

vendor-proprietary |
| Combined | ~2.82× | $2.0 \times 1.4 = 2.8 \approx 2.82$ | Only by vendor scanning own code |

****Critical implication:**** An external party (Eastern or Western) building an equivalent architecture gets the 2.0× but NOT the 1.4×. Maximum achievable by an outsider scanning Microsoft code: ~2.0× their base score.

Eastern Models in the MDASH-Anchored Tree

Using the same ratio methodology, anchored at the confirmed data points:

****HardSecBench parity confirmed:**** GLM-4.6 = Opus 4.5 at 42.9% (knowledge level)

****CyberGym relative position:**** Eastern models tested below Sonnet 4's 17.9%

****PACEBench ratio:**** Claude 3.7 (0.417) vs DeepSeek R1 (0.133) = 3.13×

Model	CyberGym (est.)	Ratio to MDASH	GPQA Diamond	Notes
MDASH	96.55%	1.0×	N/A	Ceiling – vendor privilege
Mythos	~34.2%	2.82× behind	94.6%	Best single model
Opus 4.7	~28.0%	3.45× behind	~90%	Best released Western
Opus 4.5	~23.8%	4.06× behind	~86%	HardSecBench anchor
Sonnet 4	17.9%	5.39× behind	~82%	Measured
DeepSeek V3.2	~12%	8.0× behind	~85%	Best Eastern general
DeepSeek R1	~10%	9.7× behind	71.5%	Best Eastern reasoning
Qwen3-235B	~8%	12.1× behind	65.8%	Eastern open-weight

The Knowledge Advantage Quantified

MDASH's 1.4× knowledge multiplier means:

Scenario	Base Score	× Architecture	× Knowledge	Result
MDASH (as-is)	Mythos ~34%	$\times 2.0 = 68\%$	$\times 1.4 = 96.55\%$	Full system
Hypothetical: Mythos WITHOUT MSRC knowledge	34%	$\times 2.0 = 68\%$	$\times 1.0 = 68\%$	
Architecture only				
Hypothetical: Eastern lab builds equivalent system	~12% base	$\times 2.0 = 24\%$		
$\times 1.0 = 24\%$	No vendor knowledge			
Hypothetical: Eastern vendor scans OWN code	~12% base	$\times 2.0 = 24\%$	$\times 1.4 = 34\%$	Own vendor knowledge

****Key insight:**** Even if an Eastern lab built an identical 100-agent architecture and scanned their OWN vendor's code with equivalent knowledge advantage, they'd reach ~34% CyberGym – equal to where Mythos sits as a single model WITHOUT the architecture. The base model gap (12% vs 34% = 2.85×) carries through every multiplier.

GPQA Cross-Validation

The CyberGym extrapolation should track the GPQA gaps. Testing:

Step	CyberGym Ratio	GPQA Ratio	Amplification
Sonnet 4 → Opus 4.5	1.33×	82→86% = 1.05×	4.0×
Opus 4.5 → Opus 4.7	1.18×	86→90% = 1.05×	3.6×
Opus 4.7 → Mythos	1.22×	90→94.6% = 1.05×	4.4×
Average amplification			4.0×

****Every 1 point of GPQA gap = ~4 points of CyberGym agentic gap.****

Applied to Eastern models:

- DeepSeek V3.2 GPQA gap to Mythos: $94.6 - 85 = 9.6$ pts
- $\times 4.0$ amplification = ~ 38 effective CyberGym points
- Mythos CyberGym $\sim 34\%$ vs DeepSeek V3.2 $\sim 12\%$ = 22 pts actual gap
- The amplification overestimates slightly because of CyberGym floor effects (hard to score below $\sim 5\%$), but the direction is correct

Five-Tier Model (Final)

Tier	Capability	CyberGym Proxy	Best Western	Best Eastern	Gap Type
A	Security knowledge	HardSecBench $\sim 43\%$	Opus 4.5	GLM-4.6	**Parity**
B	Exploit development	$\sim 15\text{--}20\%$	Sonnet 4 (17.9%)	DeepSeek V3 ($\sim 12\%$)	$\sim 1.5\times$ – closing
C	Zero-day discovery	$\sim 25\text{--}34\%$	Opus 4.7 ($\sim 28\%$) / Mythos ($\sim 34\%$)	GLM-5 ($\sim 15\%$)	$\sim 2\times$ – narrowing
D	Agentic harness	$\sim 68\%$ (architecture only)	MDASH w/o knowledge	None known	**Architectural**
E	Vendor-privileged AI	$\sim 96.55\%$	MDASH (full)	None known	**Access + architecture + knowledge**

What This Means

1. At the KNOWLEDGE level (Tier A): East = West. Parity confirmed.
2. At the AGENTIC level (Tier B-C): West leads $1.5\text{--}2\times$. Gap is in multi-step autonomous execution, not knowledge or reasoning.
3. At the SYSTEM level (Tier D): No Eastern equivalent exists. Building one requires engineering investment, not just better models.
4. At the PRIVILEGED level (Tier E): MDASH's score is unreachable by ANY external party because it includes vendor-specific knowledge. An Eastern vendor scanning their OWN code could theoretically reach similar scores – but the base model gap means they'd cap at $\sim 34\%$ even with equivalent architecture and knowledge multipliers.
5. The $1.4\times$ knowledge multiplier is the defender's structural edge. Vendors who scan their own code with AI will ALWAYS have an advantage over external attackers scanning the same code. This is why Glasswing/MDASH represent a genuine defensive advance – not just better models, but models with insider knowledge.

SYNTHESIS: Trees 1 + 2 $\rightarrow$ Eastern Hidden Mythos Parity/Delta

Method

Tree 1 gives us: model-vs-model capability across benchmarks.
 Tree 2 gives us: MDASH ceiling $\rightarrow$ commercially available Opus $\rightarrow$ parity with Eastern.
 Combining them extrapolates how far behind Eastern models are from the RESTRICTED Mythos that no one outside Glasswing can access.

The Chain

MDASH (96.55% CyberGym) — TREE 2 CEILING | $\div 2.82$ (system + knowledge multiplier) | $[2.0\times$ architecture + $1.4\times$ vendor knowledge] ▼ MYTHOS ($\sim 34\%$ CyberGym, 94.6% GPQA) — TREE 1 TOP | [RESTRICTED — not publicly available] | $\div 1.22$ (expert cyber ratio 73%/60%) ▼ OPUS 4.7 ($\sim 28\%$ CyberGym, $\sim 90\%$ GPQA) — TREE 1 BEST RELEASED WESTERN | [Available via API, logged, guardrailed] | CyberGym gap to Eastern: 28% vs

~12% = 2.3× | GPQA gap to Eastern: 90% vs 85% = 5 pts ▼ BEST EASTERN (DeepSeek V3.2: ~12% CyberGym, ~85% GPQA) [Available: MIT licence, self-hosted, no guardrails, no logs]

The Delta Calculation

****Eastern to Mythos – the hidden gap no one can close by downloading a model:****

Metric	Best Eastern	Mythos	Delta	Meaning
GPQA Diamond	~85%	94.6%	**9.6 points**	Reasoning depth gap
CyberGym (est.)	~12%	~34%	**2.8× ratio**	Agentic vuln capability gap
Expert cyber tasks	Not tested	73%	**Unknown**	No Eastern model tested on this benchmark
SWE-bench	~85%	~93% (est.)	**~8 points**	General coding – smallest gap
HardSecBench	42.9%	Not tested	**Parity assumed**	at knowledge level

****Eastern to MDASH – the full gap including system + knowledge:****

Metric	Best Eastern	MDASH	Delta	Meaning
CyberGym	~12%	96.55%	**8.0× ratio**	Full system gap
Decomposed:				
→ Model gap	~12% vs ~34%	–	**2.8×**	Mythos is a better model
→ Architecture gap	–	2.0×	**2.0×**	100-agent debate/prove
→ Knowledge gap	–	1.4×	**1.4×**	MSRC zero-day/patch data
→ Combined	2.8 × 2.0 × 1.4	=	**7.84× ≈ 8.0×**	Validates against measured

What Each Layer of the Delta Means

Gap Layer	Size	Can Eastern Close It?	How?	Timeline
Model capability	2.8× on CyberGym	Yes	Better models (DeepSeek V4, GLM-6)	8–12 months
Reasoning depth	9.6 pts GPQA	Yes	Reasoning training (R1-class)	5–8 months
Agentic execution	3.1× PACEBench	Partially	Agent scaffolding, tool use	12–18 months
System architecture	2.0× multiplier	Yes (with investment)	Build multi-agent harness	12–24 months
Vendor knowledge	1.4× multiplier	Only for own code	Scan own products with own data	Possible now
Mythos-class model	Restricted	No (currently)	Would need equivalent R&D investment	Unknown

The Key Insight from the Synthesis

There are THREE distinct gaps stacked on top of each other:

****Gap 1 – Publicly measurable (Tree 1):****
Eastern best vs Opus 4.7: 5 GPQA pts, 2.3× CyberGym.
This is closing. 4–6 months on GPQA. 8–12 months on agentic.

****Gap 2 – Hidden frontier (Tree 1 extrapolated):****
Eastern best vs Mythos: 9.6 GPQA pts, 2.8× CyberGym.
Mythos is not released. Eastern labs cannot benchmark against it.
They are chasing a target they cannot see. Even when they close

Gap 1, Gap 2 remains because Mythos (and its successors) keep moving.

****Gap 3 – Structural privilege (Tree 2):****
Any external model vs MDASH: 8.0× CyberGym.
This includes the 1.4× vendor knowledge multiplier that NO external party can replicate for Microsoft's code. An Eastern vendor could build their own MDASH-equivalent for THEIR OWN code – but the base model gap (2.8×) would limit them to ~34% CyberGym equivalent even with perfect architecture and knowledge.

The Parity Timeline (when does each gap close?)

2024 2025 2026 2027 2028 |-----|-----|-----|-----| |← Tier A CLOSED →| |← Tier B CLOSED —→| |← Gap 1 (Opus 4.7) —→| closes ~late 2026 |← Gap 2 (Mythos) —→| closes ~mid 2027 IF Mythos stays static (it won't — moving target) |← Gap 3 (MDASH system) —→| 2027-2028? requires architectural investment |← Knowledge gap —→| NEVER closes for external parties on vendor code ``

The moving target problem: Eastern models closing Gap 1 doesn't mean they've closed Gap 2, because Mythos will have successors. And closing Gap 2 doesn't close Gap 3, because MDASH requires system engineering + vendor knowledge they don't have. The defender's structural advantage is that each gap compounds on top of the previous one, and the knowledge gap at the bottom of the stack is permanent for external attackers.

EVIDENCE SCORECARD (Current State)

#	Round	Status	Verdict	Confidence
1	Research & media narrative	Done	Supports thesis	High (but N=1 for AI zero-day)
2	Disclosure-to-exploit timelines	Done	Supports thesis	High (Mandiant multi-year)
3	AI availability correlation	Done	Supports thesis	Moderate-High (correlation ≠ causation)
4	Breach disclosure volumes	Done	Inconclusive	Low (70% data opacity)
5	CVE volume & severity vs AI launches	Done	Supports thesis (defensive side)	Moderate-High
6	Bug bounty data	Pending	—	—
7	CISA KEV velocity	Done	Mixed — challenges breadth, supports class shift	Moderate
8	EPSS calibration	Pending	—	—
9			—	—

#	Round	Status	Verdict	Confidence
	Vendor self-discovery ratios	Pending		
10	Vulnerability class distribution	Done	Supports — class shift real, access ladder adds causality	Moderate-High
11	CVE-to-PoC timing	Pending	—	—
12	Zero-day broker disruption	Pending	—	—
13	Patch bypass / variant clustering	Pending	—	—
14	East vs West AI capability	Done	Eastern at parity Tier A-B, 3-6mo lag Tier C. Zero-day volume does NOT correlate with AI availability	High
15	Benchmark threshold for vuln ID	Done	Strong — threshold defined, three tiers, step function confirmed	High
16	MDASH patch reverse-eng speed	Baseline	T+25: 0/16 MDASH CVEs exploited. Recheck Jul 6, 2026	Pending

WORKING CONCLUSIONS (subject to revision)

What's proven: - Exploitation speed is accelerating (multi-source, multi-year telemetry) - AI capability for vulnerability exploitation exists (lab and field) - The timeline correlates with AI availability - Defensive AI is inflating severity curves (MDASH, Glasswing)

What's been challenged: - KEV-to-CVE ratio is flat (0.46% → 0.51%) — AI NOT causing more CVEs to be exploited as proportion. Growth tracks CVE volume. - Breach disclosure growth is steady slope, not hockey stick - Most trend lines are LINEAR — no AI inflection points visible - The only non-linear break is Q2 2026 critical severity spike, which maps to DEFENSIVE AI (Glasswing/MDASH), not offensive

EMERGING THESIS (revised after Rounds 14/15 — three-claim separation):

AI impact on cybersecurity now separates into THREE distinct claims, each with different evidence levels:

CLAIM 1 — SPEED/ORCHESTRATION: AI accelerates operational tempo. STATUS: SUPPORTED. Evidence: Mandiant TTE 63→7 days. PRC exploit sharing accelerating. VulnCheck: 33% of exploited CVEs attacked on or before disclosure day. CrowdStrike: 22-second initial access handoff. This is AUTOMATION of the kill chain, not new weapon creation.

CLAIM 2 — ZERO-DAY VOLUME: AI increases number of zero-days. STATUS: NOT SUPPORTED. Evidence: GTIG zero-days stable at 60-100/year. PRC: 12→5→10 (peaked BEFORE any Eastern AI at threshold, dropped in 2024 when Tier A was reached, rebounded

in 2025 but still below 2023 peak). No volume inflection at any AI milestone — East or West.

CLAIM 3 — DEFENSIVE DISCOVERY: AI helps defenders find more/harder bugs. STATUS: SUPPORTED (only non-linear signal in any dataset). Evidence: MDASH found 16 CVEs. Glasswing found 10K+ in 2 months. May 2026 critical % spiked 3.3×. CWE-862 +62% YoY (Tier 2 researchers). This is the ACCESS LADDER effect — discoverers got AI tools first.

OPEN QUESTION (new R16): Does CLAIM 3 create a perverse feedback loop? If defensive AI finds bugs → vendor patches → patch reveals bug location → attackers reverse-engineer patch using AI → faster weaponisation. Defensive AI may be ACCELERATING the n-day problem by increasing the volume of patchable bugs that become reverse-engineering targets. Test: are MDASH-discovered CVEs weaponised faster than non-AI-discovered CVEs from the same Patch Tuesday?

What's unproven: - Scale of AI-driven offensive exploitation (N=1 confirmed case) - Whether AI is the primary cause of speed increase vs confounding variables - Whether MDASH/Glasswing patches create faster reverse-engineering targets - Whether discoverers actually used AI (need researcher confirmation)

What we can't currently test (data doesn't exist or is inaccessible): - Exploit code in-the-wild analysis for LLM signatures at scale - Attacker infrastructure seizure data showing AI model usage - Controlled A/B comparison of pre-AI vs post-AI exploitation speed - Per-CVE weaponisation timing for MDASH-discovered vs other CVEs

RECOMMENDED INVESTIGATION ORDER

Priority ranked by: (a) data likely accessible, (b) decisiveness for thesis

Completed: R1, R2, R3, R4, R5, R7, R10, R14, R15

Priority	Round	Rationale
1	R16: MDASH patch reverse-engineering speed	Tests whether defensive AI discovery creates faster weaponisation via patch analysis. The perverse feedback loop hypothesis. Most decisive remaining question.
2	R11: CVE-to-PoC timing	Directly measures exploit development speed — the speed claim
3	R6: Bug bounty data	Tests whether AI discovery tools are visibly changing the researcher ecosystem
4	R9: Vendor self-discovery	Tests defensive AI impact. MDASH is first data point, need the trend
5	R13: Variant clustering	Tests whether AI is finding related bugs faster after initial patch
6	R8: EPSS calibration	Tests whether prediction models built on pre-AI assumptions still hold
7	R12: Broker disruption	Market signal — interesting but indirect

NOTES / PARKING LOT

- The 70% breach disclosure opacity is itself a finding worth reporting
- Cyber insurance loss ratios (48.8% in 2024, up from 41.6%) support increasing claims pressure, but insurance data blends all attack types, not just vuln exploitation
- Supply chain attack data (Shai-Hulud, npm) is in project knowledge but is a separate attack vector from direct vulnerability exploitation
- The "does the cause matter" framing may be the most honest conclusion — the operational reality is the same regardless of attribution
- Consider whether final output should be a briefing document, presentation deck, or speech update
- R14/R15 pair is critical: pure capability comparison, not threat attribution. Eastern models at parity on Tier A-B, 3-6 months lag on Tier C. BUT zero-day volume does NOT correlate with AI dates.
- The Fang et al. finding (GPT-4 = 87%, everything else = 0%) suggests a sharp capability cliff, not a gradient. Threshold defined as combination: HumanEval >60% AND MATH >45% AND reasoning chains. Step function confirmed.
- THREE-CLAIM SEPARATION is the key analytical contribution: Speed/orchestration (supported) vs zero-day volume (not supported) vs defensive discovery (supported). These are different phenomena with different evidence levels. Conflating them is the source of most hype-vs-reality confusion.
- R16 (MDASH patch reverse-engineering) is the most important remaining question: does defensive AI create a perverse feedback loop where more patches = more reverse-engineering targets = faster weaponisation? Test case: May 2026 Patch Tuesday, 16 MDASH-discovered CVEs vs 121 others. If MDASH CVEs get weaponised faster, defensive AI is inadvertently accelerating the n-day problem.
- R16 BASELINE RECORDED: June 6, 2026 (T+25 from May Patch Tuesday) MDASH CVEs exploited: 0/16. Netlogon (non-MDASH) exploited at T+17. Perverse feedback loop NOT YET SUPPORTED at this timestamp. RECHECK SCHEDULED: July 6, 2026 (T+55). Key metrics to track: MDASH CVE exploitation status, public PoC availability on ExploitDB/GitHub for MDASH CVEs, Word cluster exploitation status, KEV additions from May 2026 Patch Tuesday. IMPORTANT: May 2026 was first zero-day-free PT in 22 months. This may be evidence that MDASH/Glasswing are PREVENTING zero-days by finding bugs before attackers — defensive AI working as intended.

Last updated: 6 June 2026 — R16 baseline timestamp